

Stack 08 consolidated audit — bounded review receipt

Identity and complete scope

Reviewer: Codex, sole audit agent, 2026-09-27 UTC. Aggregate firmware PR #872, branch `audit/715-stack08-on-7b-20260927`, base consolidated 7b #871 at `2483977523d9b6beab52a69429ace9aeefd00f76`. Integrated code snapshot `f492d7d1728f64266cec16671d9d6e9200f0eaea`; the containing report commit and final CI/review identities are recorded in the live PR receipt. Python #120 stays `d9a02d981ee43fe3e80b28ba02466670e6e8409d`, clean review 5329239805, CircleCI 548. Other dependency pins are unchanged. This report covers the complete aggregate diff; the inherited A/B reports cover the two code-bearing adjacent review diffs.

The aggregate's file contents exactly match the tip of replacement stack B before adding this aggregate-only source/PDF. No force-push or product merge is performed. Child reviews provide mapped code coverage; #872's earlier finding-bearing verdicts remain historical and are not called clean.

One authorized breakdown and file/finding ownership

The owner authorized three initial requests total, one breakdown, and three requests per resulting unit, followed by a night stop if the audit is not achieved. The conservative recorded limit is two resulting units and nine requests maximum. Initial requests: Python #120 clean; firmware #872 review 5329251034 found one authority issue; review 5329364719 found six further issues. The single breakdown is used; no recursive split remains. A completed its checkpoint in three requests; B has used all three. The total allowance is exhausted at 9/9. The final actionable B finding is repaired below, with fresh review pending. Actual counts and outcomes belong in `audit-claims/715-08/review-budget-20260927.json` in the main worktree and the final live receipt.

Unit	Exact head and base	Owned code and findings
A #873	1172cd309a280845c8d14c372ee45ec7d343e207 on accepted 7b 2483977523d9b6beab52a69429ace9aeefd00f76	Report generator/tests, CI report-test/history/companion metadata, Python pin and duplicate nanopb removal. Findings 4114517037, 4114517067, 4114517093: platform authority, empty ledger and exact product skip reasons. Source/PDF and all 23 historical paths are in the inherited A audit/reconciliation.
B #874	ce196827223c88097890451f96fbccfa4938522d on A 1172cd309a280845c8d14c372ee45ec7d343e207	Preflight, shared cppcheck invocation/version/tests and CI static-analysis steps. Findings 4114517060, 4114517076, 4114517108: remove extraction, verify pinned analyzer and execute report tests once.

The workflow file is owned by both adjacent units in disjoint hunks: A adds report gate/history and companion binding; B replaces static-analysis installation/invocation and adds its focused tests. No production firmware, Python production library, native test or ABI behavior changes. The accepted 7b implementation already supplies the scoped 7.15 display and one-level inner-call behavior. Python adds EX40–EX44 and report requirements; all 39 predecessor runtime method ASTs are unchanged.

Findings, verification and limitations

A selects waiver authority from GitHub's platform base event, validates a full nonzero SHA, and constrains the candidate ledger to that base. Independent fixtures bind a known base distinct from the candidate head and environment pin. Local rehearsal uses the merge base with accepted remote 7b. A round 1 review 5329498209 found two unsafe non-PR fallback choices and a stale reconciliation snapshot. Push/manual reports now require the independently configured repository Actions variable `KK_ACCEPTED_WAIVER_SHA` or fail closed; no setting was changed. PR authority ignores that override. Tests cover both event modes, missing/malformed authority and PR isolation. The reconciliation JSON and A source report now bind the same repaired code snapshot. A round 2 review 5329587276 also caught a stale JSON test-count field; it now agrees with all 18 passing methods, and authority/skip-reason descriptions are synchronized. Its Solana high finding is technically declined: bounds 8/32/64 remain at lines 16–18. A parsed comparison preserves all 29 effective Solana and 56 Osmosis options against accepted 7b; only identical duplicate copies were removed. Exact counts are retained in JSON and local evidence. A comment marks the retained bounds at the former duplicate location. A completed its checkpoint on review 5329724450: Findings: None, no inline findings and no unresolved threads. The generic overview identifies no concrete actionable issue under the SOP; the prior stop classification was corrected. A unique empty ledger is valid; absent/duplicate ledgers fail. Every dedicated full/BTC

contract needs the expected status and exact product-specific skip reason. Eighteen gate tests pass, including corruption of every expected skip; actual four full/BTC contract artifacts pass. Malicious replacement of the whole checker/workflow remains a code-review boundary.

B shares one explicit argv script between CI and local Docker. Both use Ubuntu cppcheck package 2.13.0-2ubuntu3, verify dpkg and executable version at every invocation, and propagate process failures. Five analyzer tests cover literal argv, stale package, shadowed executable, analyzer failure and invalid invocation. Seven preflight boundary tests pass (30 including the 18 report-gate and five analyzer tests). Preflight executes the report suite once. The original command-corruption allegation was not reproduced in observed argv; extraction was nevertheless eliminated. Package/version and arguments are matched; operating-system images across architectures are not claimed byte-identical.

Local qualification inherited from unchanged runtime/Python: 65 wire/runtime tests, 39 compiler/catalog/protocol/report tests, 657 native firmware tests, 11 inspected EX42 frames; negative controls reject disabled attacks/chunk bounds and corrupted evidence. Previous replacement preflights passed; all three preflights are repeated after this authority repair and refreshed report freezes. The aggregate preflight is rerun after this final receipt edit before push. Previous aggregate CI 36302640527 passed 1,497 tests with 89 expected skips and zero failure/error. Final aggregate and child CI must bind exact firmware/Python SHAs, both PR URLs, run URL and PDF digest; both ARM variants, native/emulator/integration and release-evidence gates must pass before acceptance.

Current 7.15 owner scope is preserved: optional fields remain visible; unsupported hiding conditions, nested iteration/slices, extra formatter kinds, deeper recursion and typed embedded calls are deferred/refused. Missing or unsupported inner definitions retain explicit blind fallback in AdvancedMode. DELEGATECALL execution-context policy is reserved for 7.16. Hardware validation, assembled release acceptance, product merges and publication remain separate gates. No final clean review or audit completion is claimed at this source freeze; the live receipt must record the delivered exact-head outcomes and remaining budget honestly.

Historical B round 1 findings and verification

Review 5331723008 found two inline issues plus concrete body-only suggestions. The basename search could accept an unrelated file or a comment; preflight now configures the actual test CMake tree with full features and compares tracked test paths against compile_commands.json. Linking is omitted and firmware is not compiled by this source-membership check; real set/list/iff/add_subdirectory semantics remain. Repository-root source paths are exposed through temporary directory aliases. Missing CMake or configuration errors fail closed. This checks membership in the configured full-feature test graph, not runtime test success; native CI remains required.

GNU timeout is replaced by Python subprocess.run(timeout=20), which works on macOS and reports missing, failed or timed-out Docker probes. Whitespace checks independently validate the committed upstream-base-to-HEAD range and the HEAD-to-working-tree range, so an uncommitted cleanup cannot mask a bad committed push; PREFLIGHT_BASE explicitly selects the adjacent review base or is required for a first push without an upstream. CI creates the analyzer report before invocation so early package/executable failure still leaves an uploadable report. The analyzer cache is ignored locally. The argv regression asserts every flag, include, define, template, output path and source directory, allowing only the host CPU count to vary.

Five new boundary tests exercise a same-basename collision, comment and unused-list rejection, a repository-root CMake source, committed/worktree whitespace (including an uncommitted fix masking committed errors), absent upstream, and Docker timeout/failure behavior. All 28 combined preflight/analyzer/report tests pass, and the structural check passes on the real repository. Initial harness validation caught a CMAKE_SOURCE_DIR relocation problem; temporary directory aliases fixed it and a real-CMake fixture now covers that case. No production firmware, runtime suite, Python pin or A code changed. Final preflight must run after this source/PDF freeze, followed by new exact-head CI/report verification and B request 2/3; that historical review delivered the further findings below. Earlier successful runs describe earlier B/aggregate heads.

Historical B round 2 final-attempt repairs

Review 5331887311 identified a missing C translation-unit inventory (inline 4116802451) and missing CI execution of the preflight-check suite (body-only). The inventory now scans tracked files under unittests and selects .c, .cc, .cpp, .cxx and uppercase .C paths. The same-basename/comment/unused-list fixture covers all five extensions, rejecting each omitted target entry and passing after target registration. Distinct filenames preserve this fixture on case-insensitive macOS. The actual repository source-membership check passes with all tracked C and C++ translation units included, subject only to the existing named hive.cpp ownership exception.

CI's existing Stage-1 validation command now invokes the five preflight boundary tests alongside the five analyzer and 18 report-gate tests. The exact command passes all 28 tests locally. The real CMake fixture configures native C/C++ targets without compiling firmware or linking external dependencies; missing tooling or generation failure fails the test. Workflow lint and the real source graph pass. Final preflight, hosted CI and report identities must pass at this frozen head before B's third and

final request. A and Python are unchanged and remain accepted. Initial budget 3/3, one breakdown used, A 3/3 complete, B 2/3 used; no fourth B request or recursive split is authorized.

Final B finding repaired; ready for fresh review

Review 5332001128 on 6dff9f55bd2c7dbfe762a5edfe0154b6a04289df contained a concrete body finding despite Findings: None and zero inline/unresolved threads. An explicit PREFLIGHT_BASE naming a descendant could hide committed whitespace errors because merge-base reduced the range to HEAD. A real Git fixture reproduced that bypass in the old helper. Explicit bases now resolve once to a commit and must pass git merge-base --is-ancestor against HEAD before range validation. Missing, blank, option-like, divergent and descendant values fail closed. Valid ancestors, annotated ancestor tags and HEAD are accepted. Implicit upstream selection retains merge-base behavior. Committed and working-tree whitespace remain independently checked.

Two added test methods exercise these rejected and accepted boundaries in real temporary repositories. All 30 report/analyzer/preflight tests pass locally. The second body suggestion about stale report identity is declined: the source labels the pre-report code snapshot, while the containing report commit is recorded in the live PR and CI manifest. This freeze keeps that distinction explicit. Historical sections above record prior checkpoints rather than current readiness claims.

Python changes are now merged upstream through keepkey/python-keepkey PR #229 into reconcile/upstream-sync at 76d876a86fe92e791f87c8db3dccec04bf05af7a. The firmware dependency remains the audited d9a02d981ee43fe3e80b28ba02466670e6e8409d, which is an ancestor of that canonical merge. A and its accepted checkpoint are unchanged. Final local preflight and exact-head hosted CI/report verification are recorded separately after this immutable source/PDF freeze. Local readiness does not assert fresh Copilot acceptance: initial 3/3 plus A 3/3 plus B 3/3 exhaust the nine-request allowance; no additional request or breakdown was made.

Complete adjacent aggregate inventory

Added	Deleted	Path
16	26	.github/workflows/ci.yml
3	0	.gitignore
1	1	deps/python-keepkey
110	0	docs/release/audit-units/715-08-audit-20260927.md
-	-	docs/release/audit-units/715-08-audit-20260927.pdf
78	0	docs/release/audit-units/715-08-consolidated-audit-20260927.md
-	-	docs/release/audit-units/715-08-consolidated-audit-20260927.pdf
-	-	docs/release/audit-units/715-08-local-evidence-20260927.tgz
175	0	docs/release/audit-units/715-08-reconciliation-20260927.json
72	0	docs/release/audit-units/715-08B-audit-20260927.md
-	-	docs/release/audit-units/715-08B-audit-20260927.pdf
0	1	include/keepkey/transport/messages-osmosis.options
2	3	include/keepkey/transport/messages-solana.options
1	0	scripts/cppcheck-version
32	0	scripts/cppcheck.sh
96	7	scripts/generate-test-report.py
103	0	scripts/preflight.sh
92	0	scripts/preflight_checks.py
248	0	scripts/test_generate_test_report.py
124	0	scripts/test_preflight_checks.py
91	0	scripts/test_preflight_cppcheck.py